

Class 32 Phishing Analysis Tools & Prevention For SOC

THM Room - Phishing Analysis Tools

Identifying Artifacts

Header Artifacts

When you begin your analysis with the email header, you should take note of the following points:

- Sender email address: Where did the email originate from?
- Sender IP address: What is the source IP, and what does a reverse lookup reveal?
- Email Subject Line: Does it contain urgency or a call to action?
- Recipient email address Who is the intended recipient (To/CC/BCC)?
- Reply-To email address: Where are responses being directed?
- Data and Time: When was the email sent?

Body Analysis

Next comes the email body, which has its own set of artifacts to be aware of:

- URLs and hyperlinks: Identify all links and expand shortened URLs to reveal their true destination.
- Attachment name(s): What files are included, and do their names or extensions appear suspicious.
- Attachment hash: Generate a hash value for threat intelligence lookups.

Congratulations! You Won a Free Hat! Claim Now!



TryHatMe Team <noreply12345@tryhatme.com>
To: david@hatmail.com

Mon, Mar 23 at 10:02am

Dear Sir/Madam,

You have won a free hat from your favorite hat provider, TryHatMe. Click the button below to claim your new hat!



Claim Your Hat!

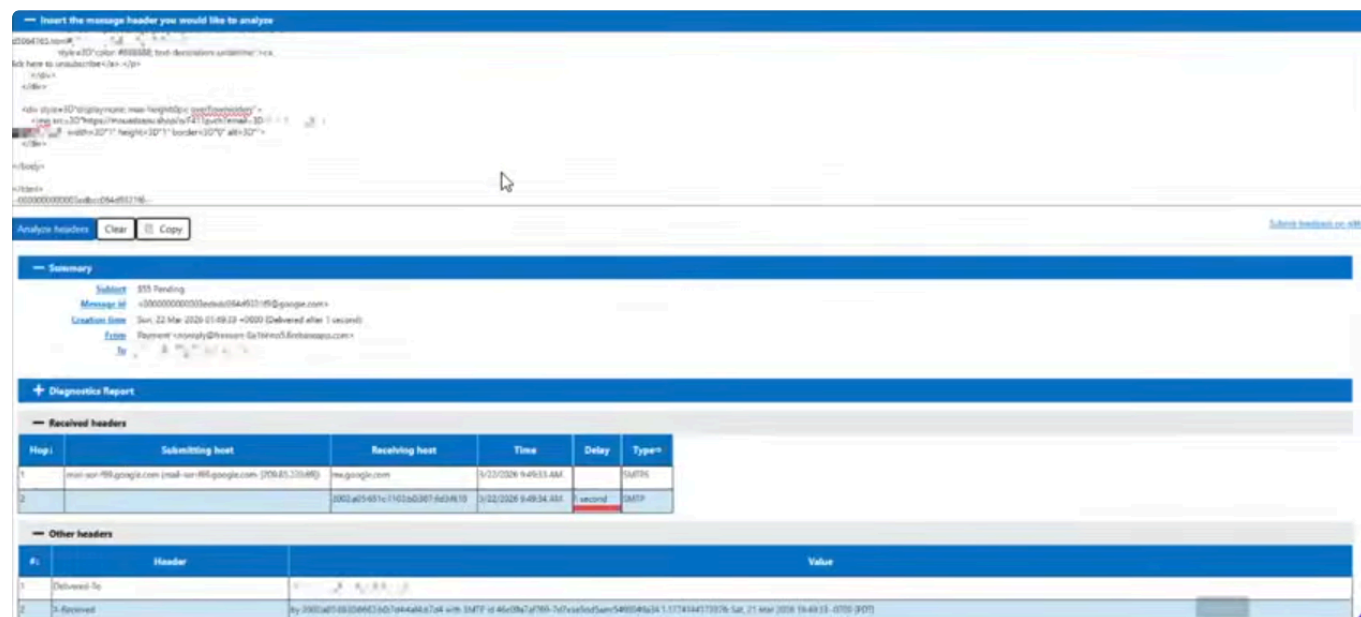
Email Header Analysis

Mail Header Analysis

Messageheader, a part of the google admin toolbox, helps analyze email headers. By simply pasting the full header into the tool, you can quickly extract key details such as sender's IP address, routing path and potential misconfiguration

MessageId	1F16Y.SNHR8.qmail@localhost.localdomain				
Created at:	3/19/2026, 8:41:42 PM GMT+8 (Delivered after 4 hours)				
From:	Ozempic by MEDVI <MEDVI.lvsupportgqd@xmsyurwxkpxcsqbowehipdty.com>				
To:	[Redacted]				
Subject:	Lose weight with Medvi - or get your money back				
SPF:	pass with IP 212.81.58.178 Learn more				
DKIM:	permemor with domain xmsyurwxkpxcsqbowehipdty.com Learn more				
#	Delay	From *	To *	Protocol	Time received
0	4 hours	pdr9-services-05v.prod.PYY28AQM.org	pdr9-services-05v	ESMTP	3/20/2026, 12:41:42 AM GMT+8
1	1 sec	wolff.ayav.net	[Google] mx.google.com	ESMTPS	3/20/2026, 12:41:43 AM GMT+8
2			[Google] 2002:a5d:588e:0:b0:439:bee:43aa	SMTP	3/20/2026, 12:41:43 AM GMT+8
3			[Google] 2002:a2e:8843:0:b0:387:6d3:f610	SMTP	3/20/2026, 12:41:43 AM GMT+8

Another great tool is Message Header analysis, can perform the same type of analysis. Check it out in the screenshot below.



IP and URL Reputation Analysis

When investigating suspected phishing emails, it is important to determine the origin of any identified IP addresses and assess the reputations of any associated IPs or URLs. These indicators can reveal whether the infrastructure is legitimate or tied to known malicious activity. Fortunately, several free tools are available that allow analysts to quickly perform these checks and gain valuable insights into potential threats.

IPinfo is a simple and effective tool for gathering information about an IP address. By entering an IP, you can quickly view details such as its geographic location and associated organization. This helps analysts determine whether an IP is potentially malicious.

URLScan.io is a tool that enables analysts to safely investigate websites without visiting them directly. By submitting a URL, the service simulates a real user browsing session and records all activity generated by the page. It also captures a screenshot of the site and provides insight into its behavior, helping analysts quickly identify suspicious or potentially malicious content.

capital-one.com

34.98.99.30 

URL: <http://capital-one.com/>

Submission: On July 01 via api (July 1st 2021, 6:27:50 pm UTC) from US 

[Summary](#) [HTTP](#) [Redirects](#) [Links](#) [Behaviour](#) [Indicators](#) [Similar](#) [DOM](#) [Content](#) [API](#)

Summary

This website contacted 5 IPs in 2 countries across 5 domains to perform 14 HTTP transactions. The main IP is 34.98.99.30, located in Kansas City, United States and belongs to GOOGLE, US. The main domain is capital-one.com.

capital-one.com scanned 61 times on urlscan.io

Show Scans 61

urlscan.io Verdict: No classification 

Live information

Google Safe Browsing:  No classification for capital-one.com

Current DNS A record: 34.98.99.30 (AS15169 - GOOGLE, US)

Screenshot

[Live screenshot](#)

[Full image](#)



Talos IP & Domain Reputation Center is a threat intelligence tool from Cisco that enables analysts to assess the reputation of IP addresses, domain, and networks. By submitting an indicator, you can quickly assess whether it has been associated with malicious activity and view its classification.

Lookup data results for IP Address

209.85.220.69

IP & Domain Reputation Overview | Email & Spam Trends

LOCATION DATA

 MOUNTAIN VIEW, UNITED STATES

OWNER DETAILS

IP ADDRESS	209.85.220.69
FWD/REV DNS MATCH	Yes
HOSTNAME	mail-sor-f01.google.com
DOMAIN	google.com
NETWORK OWNER	GOOGLE INC.

CONTENT DETAILS

CONTENT CATEGORY: No established content categories

Think these category details are incorrect?

[Submit Content Categorization Ticket](#)

REPUTATION DETAILS

SENDER IP REPUTATION:  Not Listed [Submit Sender IP Reputation Ticket](#)

WEB REPUTATION:  Not Listed [Submit Web Reputation Ticket](#)

EMAIL VOLUME DATA

	LAST DAY	LAST MONTH
EMAIL VOLUME	7.1	4.6
VOLUME CHANGE	2.99%	

BLOCK LISTS

BL.SPAMCOP.NET	Not Listed
CB.LABUSEAT.ORG	Not Listed
PBL.SPAMHAUS.ORG	Not Listed
SBL.SPAMHAUS.ORG	Not Listed

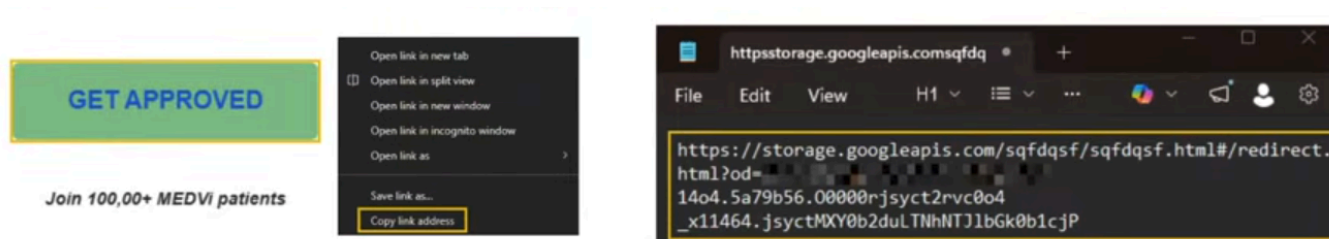
TALOS SECURITY INTELLIGENCE BLOCK LIST

ADDED TO THE BLOCK LIST: No

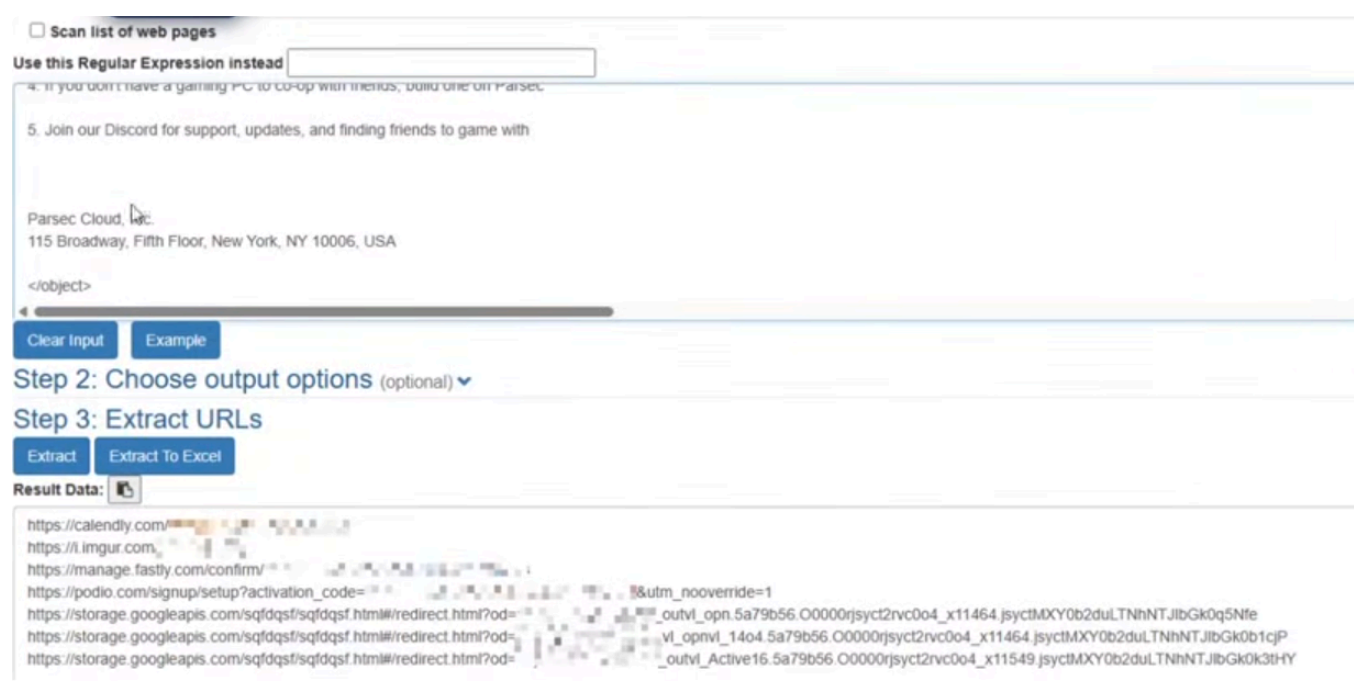
Email Body Analysis

Mail Body Analysis

Determining the destination of a link within an email can be as easy as right-clicking the link and selecting copy link address (The option's name may vary depending on your browser or email provider). From here, you can safely assess the URL without actually following it to the destination page.

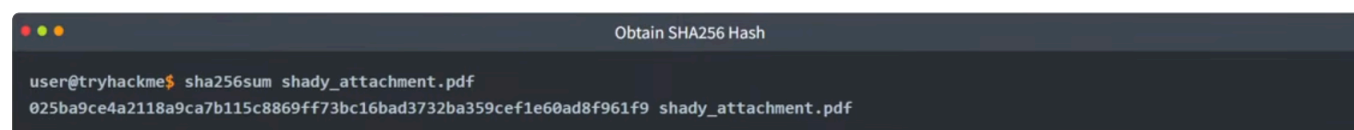


Another effective way to identify URLs in an email is to use a URL extraction tool. These tools let you paste raw email content and automatically parse all embedded links, saving time and reducing the risk of missing hidden or obfuscated URLs. Tools like CyberChef can also perform this function, making them a versatile option for email analysis.



Email Attachments

If the email you are investigating contains an attachment, it may be tempting to download it directly using your email client. However, attachments should only be downloaded in a controlled environment, such as a lab machine or sandbox, to reduce the risk of accidental execution. Once safely obtained, you can use tools like sha256sum command in a Linux environment to generate a hash value for further analysis and reputation checks.



Once you've obtained the hash value, several sites can safely assist with the analyzing the attached file. Let's return to Talos IP & Domain Reputation Center from the previous task and analyze the hash value from the above. In this case, the file is labelled as Phishing, Malicious and Spam, indicating that the file is likely harmful.

FILE REPUTATION



Malicious

TALOS WEIGHTED FILE REPUTATION SCORE

Score not available.

Think this reputation is incorrect?

[Submit a File Reputation Ticket](#)

SHA256
025BA9CE4A2118A9CA7B115C8869FF73BC16BAD3732BA359CEF1E60AD8F961F9

Clicking the above SHA256 will redirect you to Cisco ThreatGrid. This service requires a ThreatGrid subscription.

FILE SIZE 41939 bytes

SAMPLE TYPE PDF document, version 1.4

CISCO SECURE ENDPOINT DETECTION NAME W32.Auto:025ba9.in03.Talos

ASSOCIATED DOMAINS FOR THIS HASH
Domains not available.

DETECTION ALIASES

- [UNKNOWN_MALICIOUS] Phishing/PDF.Malurl.XG5
- detected
- PDF:PhishingX-gen [Phish]
- PDF.Spam.Heur.1
- malware.confidence_100
- PDF/Agent.X.gen/Camelot

*Limited to SHA256 lookup

VirusTotal is a widely used tool that allows analysts to check the reputation of files, URLs, IP addresses, and domains using data from dozens of security vendors. By submitting a file or indicator, you can quickly determine whether it has been flagged as malicious and review detailed detection results. VirusTotal also allows users to upload files and submit URLs for analysis, making it a powerful resource for investigating suspicious artifacts.



Community Score 1 / 65

33/65 security vendors flagged this file as malicious

025ba9ce4a2118a9ca7b115c8869ff73bc16bad3732ba359cef1e60ad8f961f9

pdf-legitimo.pdf

pdf checks-user-input checks-network-adapters long-sleeps runtime-modules direct-cpu-clock-access detect-debug-environment

Size 40.96 KB Last Analysis Date 1 year ago

[Reanalyze](#) [Similar](#) [More](#)

DETECTION DETAILS RELATIONS BEHAVIOR COMMUNITY 2

Popular threat label phishing.phishingx Threat categories phishing trojan Family labels phishingx

Security vendors' analysis

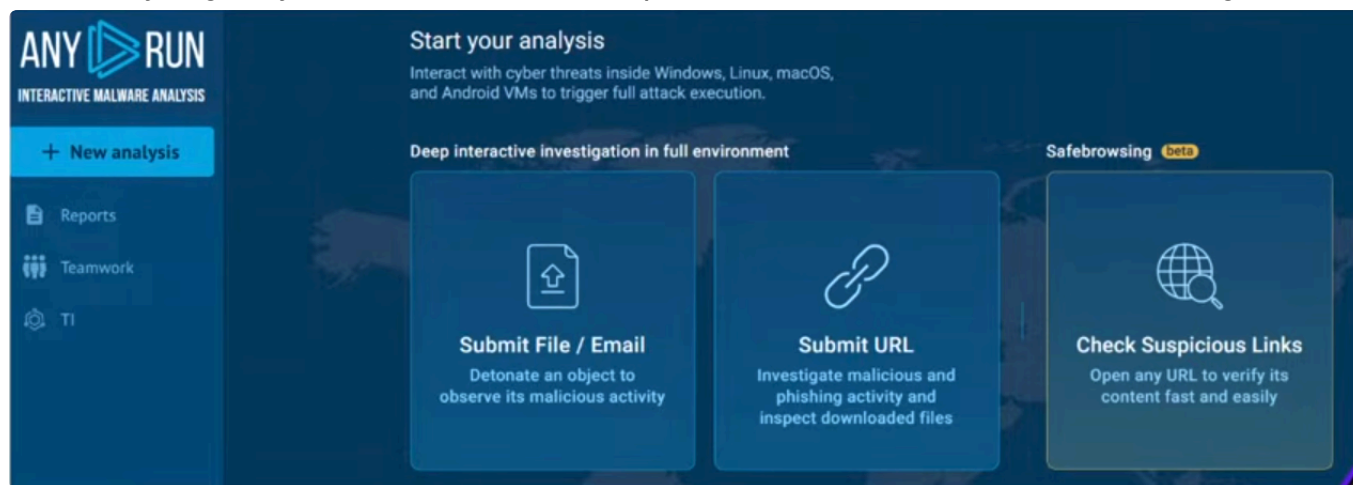
AhnLab-V3	Phishing/PDF.Malurl.XG5	Arcabit	PDF.Spam.Heur.1
Arctic Wolf	Unsafe	Avast	PDF:PhishingX-gen [Phish]
AVG	PDF:PhishingX-gen [Phish]	Avira (no cloud)	HTML/Malicious.PDF.Gen
BitDefender	PDF.Spam.Heur.1	Cynet	Malicious (score: 99)
DrWeb	PDF.Phisher.197	Emsisoft	PDF.Spam.Heur.1 (B)

Do you want to automate checks?

Malware Sandboxes

Anyrun

ANY.RUN is an interactive malware sandbox that allows analysts to safely execute and observe suspicious files and URLs in real time. Unlike traditional sandboxes, it provides a hands-on experience in which you can interact with the environment, monitor processes, view network activity, and analyze system changes as they happen. This makes it a powerful tool for understanding how malware behaves and identifying key indicators of compromise in a controlled setting.



Hybrid Analysis

Similar to the tool above, Hybrid Analysis is a free malware analysts sandbox that allows analysts to upload and examine suspicious files in a controlled environment. It provides detailed insights into file behavior, including system changes, network activity, and indicators of compromise, helping analysts better understand the potential impact of a malicious file.



File/URL File Collection Report Search YARA Search String Search

This is a free malware analysis service for the community that detects and analyzes unknown threats using a unique Hybrid Analysis technology.



Drag & Drop For Instant Analysis

or

 Analyze

JOESandbox

JOESecurity created the JOESandbox for advanced malware analysis. It performs both static and dynamic analysis on suspicious files and URLs. It generates comprehensive reports that highlight behavior,

indicators of compromise, and threat classifications.

The screenshot displays the Joe Reverser web interface. At the top, a header bar features the Joe Reverser logo (a blue circle with a red and blue path) and the text "Joe Reverser — Agentic Malware Reverse Engineering and Phishing Analysis". Below this, it states "Analyze binary files, e-mails (MSG / EML), PDF and URLs" and includes two buttons: "Try Joe Reverser" and "Read more".

The main interface is divided into two sections:

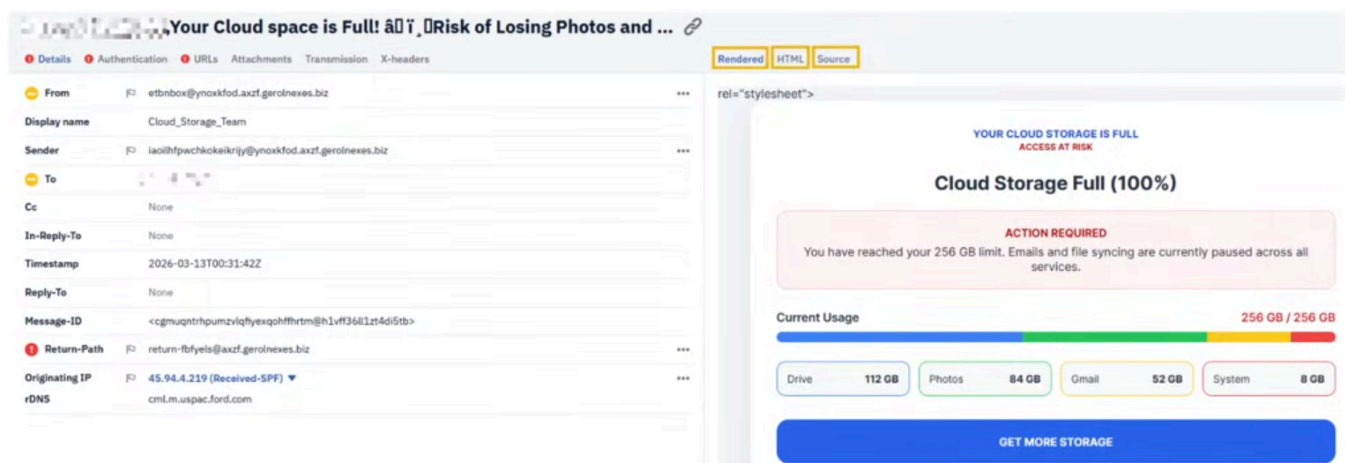
- 1 Choose Analysis Architecture**: This section contains five icons representing different operating systems: Windows (blue square with white logo), macOS (grey square with black Apple logo), Android (red square with white robot logo and a red "EOL" tag), Linux (grey square with black penguin logo), and Advanced (grey square with a black pencil icon).
- 2 Define Sample Source and Choose Analysis System**: This section contains three main options:
 - Upload Sample**: Includes a "Choose file(s)" button (max. 100mb) and a note: "Make sure to use the original sample name. Do not rename samples!".
 - Browse URL**: Includes a text input field for a URL.
 - More Options**: Includes a "Download & Execute File" button and a "Command Line" button.

Using PhishTool

A powerful platform that streamlines phishing investigations is PhishTool. It is designed for security professionals across multiple disciplines. PhishTool automates much of the manual work involved in analyzing suspicious emails. Whether you are a SOC analyst triaging user-reported messages, a threat intelligence analyst collecting indicators, or a researcher investigating phishing kits, PhishTool brings everything together in one place. By combining threat intelligence, OSINT, email metadata, and automated analysis workflows, PhishTool provides a centralized view of phishing activity, helping you quickly identify malicious intent and extract valuable indicators of compromise.

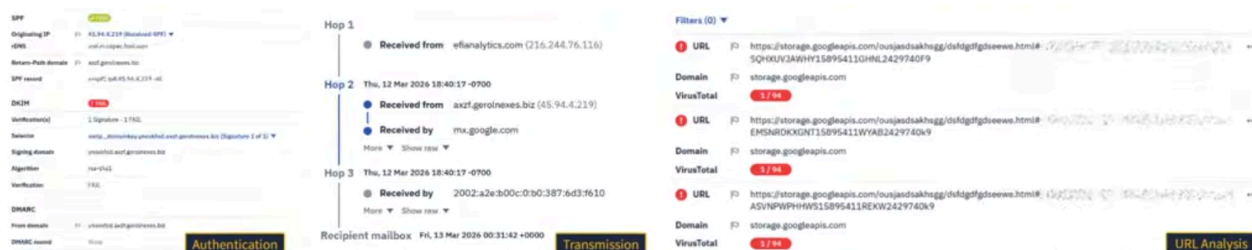
Identifying Artifacts

Upon uploading an email to PhishTool, you are presented with many of the valuable artifacts that we discussed in the second task. On the right-hand side, the tool provides the rendered HTML view, similar to what you'd see in your inbox, the raw HTML, and also the message source. Pretty useful!



Further Analysis

By navigating the tabs across the top of PhishTool, you can analyze key components of the email, including authentication results, transmission paths, and any embedded URLs. If the email contains attachments, they can also be reviewed and analyzed directly within the platform, giving you a comprehensive view of the message in one place.



One of the PhishTool's Standout feature is its integration with VirusTotal, allowing you to view reputation and detection results without leaving the tool. This seamless integration helps speed up investigation by bringing external intelligence directly into your workflow.

Resolving The Case

Once your analysis is complete, PhishTool allows you to formally document your findings. As shown below, the email can be marked as malicious, with key artifacts, such as sender addresses, originating IP, and embedded URLs, to be flagged. You can then add investigation notes and click Resolve, mirroring the documentation and case closure process used in a real SOC environment.

Disposition ▼

Malicious

Flagged artifacts ▼

⊗ From email address	etbnbox@ynoxkfod.axzf.gerolnexes.biz
⊗ From domain	ynoxkfod.axzf.gerolnexes.biz
⊗ Return-Path email address	return-fbfyels@axzf.gerolnexes.biz
⊗ Originating IP	45.94.4.219 (Received-SPF)
⊗ Message URL	https://storage.googleapis.com/ousjasdsakhsgg/dsfdgdfgdseewe.html# _sqztetbbpbe1955UHBCSQHXUVJAWHY15895411GHNL242974 0F9
⊗ Message URL	https://storage.googleapis.com/ousjasdsakhsgg/dsfdgdfgdseewe.html# _nwcqzhcmsv1955EJBXEMSNRDKXGNT15895411WYAB242974 0k9
⊗ Message URL	https://storage.googleapis.com/ousjasdsakhsgg/dsfdgdfgdseewe.html# _eoriupgsco1955UOTDASVNPWPHHWS15895411REKW242974 0k9

Classification codes ▼

⊗ MAL_URL Malicious URL

Notes

This is a malicious phishing attempt.

Resolve

THM Room - Phishing Prevention

Sender Policy Framework (SPF)

Dmarcian, a platform dedicated to helping organizations protect email domains from phishing, defines "Sender Policy Framework (SPF)" as follows:

"Sender Policy Framework (SPF)" is used to authenticate the sender of an email. With an SPF record in place, Internet Service Providers can verify that a mail server is authorized to send email for a specific domain. An SPF record is a DNS TXT record containing a list of the IP addresses that are allowed to send email on behalf of your domain."

Let's take a look at a workflow diagram for SPF



So, in essence, when an email is sent, the receiving mail server checks the domain's SPF record to verify whether the sending server is authorized to send messages on behalf of that domain. The delivery of the email (intended action) is based on the result of the SPF record verification.

Verification Result	Intended Action
Pass, Neutral, None	Accept (Allow and process the email)
Softfail, PermError	Flag (Mark as suspicious but allow)
Fail, TempError	Reject (Immediately discard the email)

SPF Records

Let's take a look at a sample SPF record and break down its format. Further information on SPF Record Syntax can be found [here](#).

```
v=spf1 ip4:127.0.0.1 include:_spf.google.com -all
```

- `v=spf1` Signifies the start of the SPF record
- `ip4:127.0.0.1` Specifies which IP can send mail (IPv4 in this case)
- `include:_spf.google.com` Specifies which domain can send mail
- `-all` Non-authorized emails will be rejected

Tools

The SPF Surveyor tool from dmarcian enables us to gain a visual look at DNS records. It also helps ensure the record uses the correct syntax.

Let's take a look at TryHackMe's SPF record as an example.

```
v=spf1 include:_spf.google.com include:email.chargebee.com  
include:7168674.spf@5.hubspotemail.net ~all
```

You may notice that no IP addresses are visibly present in the main record, but three domains are listed. In this case, all IP addresses authorized by the domains will be recognized as legitimate senders.

- `_spf.google.com`
- `email.chargebee.com`
- `7168674.spf@5.hubspotemail.net`

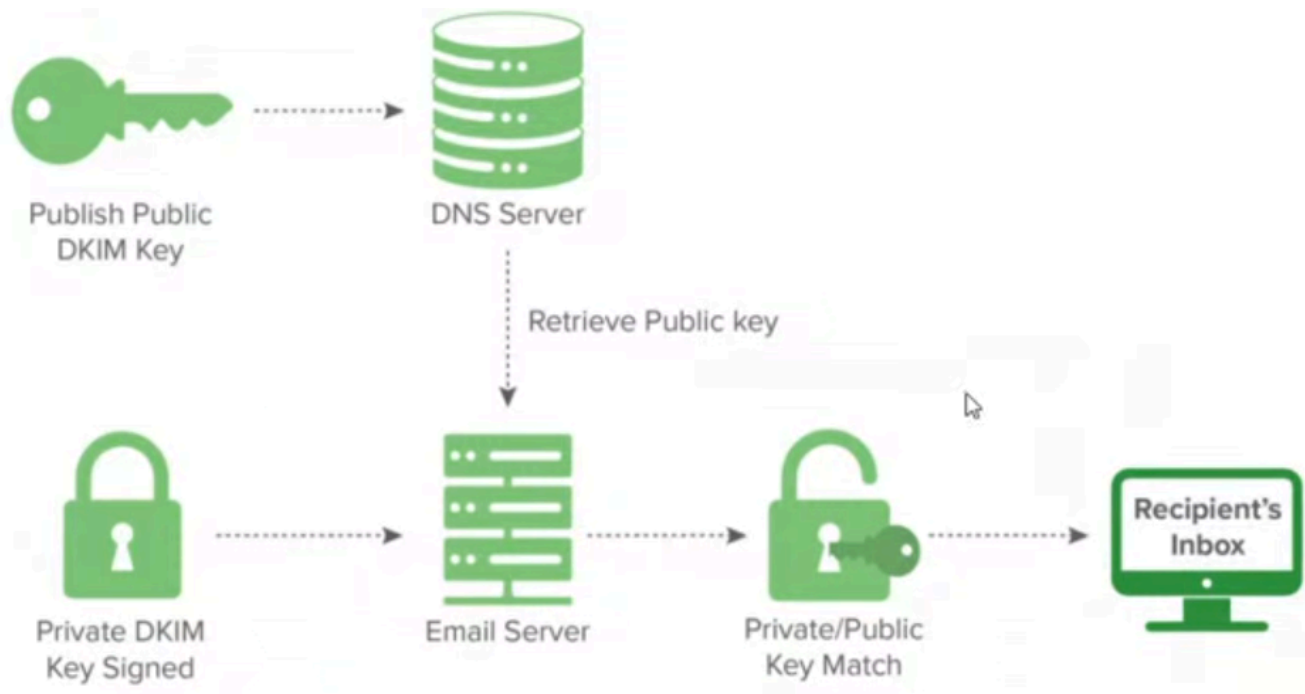
Google Admin Toolbox Messageheader allows you to analyze delivery details using an email's full header. It shows various record results, including SPF. checkout the example below, which shows the SPF record as `softfail` with `IP Unknown!`. A `softfail` means the sending mail servers not used as an authorized sender, but the receiving server will still accept the email and flag it as suspicious. In this case, the sending IP address could not be verified.

MessageId	20251001123456.abc123@mail.attacker.thm
Created at:	10/1/2025, 8:34:55 PM GMT+8 (Delivered after 1 sec)
From:	"Acme Billing" <billing@example.com>
To:	victim@receiver.thm
Subject:	Invoice #12345 – Action Required
SPF:	softfail with IP Unknown!

DomainKeys Identified Mail (DKIM)

DKIM stand for DomainKeys Identified Mail and is used for the authentication that is used for DMARC alignment. A DKIM record exists

in the DNS, but it is more complex than SPF. DKIM's advantage is that it can survive forwarding, which makes it superior to SPF and a foundation for securing your email.



Let's break it down. When an email is sent, the sending mail server uses a private key to add a digital signature to the email. The receiving server retrieves the public key from the domain's DKIM record to verify that the message truly came from the domain. If the signature matches, the email is authentic; otherwise, it may be flagged or rejected.

DKIM Records

Here is a sample DKIM record, along with its components.

```
v=DKIM1; k=rsa; p=<public_key>
```

- `v=DKIM1` = Specifies the version of DKIM being used (optional)
- `k=rsa` = The key type. The RSA encryption algorithm is standard
- `p=<public_key>` = This is the public key that will be matched to the private key to verify the DKIM signature

Note: DKIM record formats vary and may include other tags depending on the mail provider or implementation.

Dmarcian has some great resources if you wish to learn further about DKIM. You can also check out their DKIM Record Checker and Validator.

The image below is a snippet of an email header that was marked as spam with a DKIM result of permerror, indicating a permanent failure in DKIM

verification. This could be the result of an invalid signature, a missing or incorrect DNS record, a forwarding server making a modification, or a misconfiguration in DKIM setup.

```
Received: from relay.fakevendor-mail.net (203-0-113-94.isp.example.net. [203.0.113.94])
  by mx.traininglab.com with ESMTPS id lab123456789abc.987.2025.10.06.10.42.21
  for <learner@traininglab.com>
  (version=TLS1_3 cipher=TLS_AES_256_GCM_SHA384 bits=256/256);
  Mon, 06 Oct 2025 10:42:21 +0000
Received-SPF: pass (traininglab.com: domain of return@marketing-notify.appmailer.securemail.example
designates 203.0.113.94 as permitted sender) client-ip=203.0.113.94;
Authentication-Results: mx.traininglab.com;
  dkim=permerror (no key for signature) header.i=@alerts.securemail.example header.s=default;
  spf=pass (traininglab.com: domain of return@marketing-notify.appmailer.securemail.example
designates 203.0.113.94 as permitted sender) smtp.mailfrom=Return@marketing-
notify.appmailer.securemail.example;
  dmarc=fail (p=none dis=none) header.from=securemail.example
```

Domain-Based Message Authentication, Reporting and Conformance (DMARC)

“DMARC, an open source standard, uses a concept called alignment to tie the result of two other open source standards, SPF (a published list of servers that are authorized to send email on behalf of a domain) and DKIM (a tamper-evident domain seal associated with a piece of email), to the content of an email.”

This means that DMARC ensures the sender's domain matches the domains verified by SPF and DKIM. If the alignment fails, DMARC instructs the recipient server on how to handle the email based on a policy specified in the record.

DMARC Records

Here is a breakdown of a DMARC record and its components.

v=DMARC1; p=quarantine; rua=postmaster@website.com

- v=DMARC1 The version of DMARC (required)
- p=quarantine The DMARC policy (quarantine=move to spam folder)
- rua=postmaster@website.com An optional tag. In this case, aggregate reports will be sent to the email specified

Domain checker

Another great tool by dmarcian that inspects DMARC, SPF, and DKIM records to identify any issues. Let's try it out on `microsoft.com`.

In the screenshot below, you can see that `microsoft.com` passed all the checks. Clicking the details will allow you to examine each record and policy more closely. As shown in the record below, all emails that fail the DMARC check will be rejected based on the `p=reject` policy tag.

Well done! You have a valid DMARC record that provides visibility into the entirety of your email program(s) and helps ensure you meet email sending best practices. Your domain takes full advantage of the domain protections afforded by DMARC.

The checks performed here are similar to those done by mailbox providers such as Google, Yahoo and Microsoft. DMARC, SPF and DKIM records live in your domain's DNS and are used by mailbox providers to separate legitimate email from abuse. Based on your strict DMARC policy, mailbox receivers can reliably identify and block phishing, spoofing and unauthorized use of your domain.

GET STARTED

✓ DMARC

Your domain has a valid DMARC record and your DMARC policy will prevent abuse of your domain by phishers and spammers.

— Details

```
v=DMARC1; p=reject; pct=100; rua=mailto:itex-rua@microsoft.com; ruf=mailto:itex-ruf@microsoft.com; fo=1
```

To understand and fix the specific errors, use our [DMARC Inspector](#).

Secure/Multipurpose Internet Main Extentions(S/MIME)

Secure/Multipurpose Internet Mail Extensions (S/MIME) is a standard protocol for sending digitally signed and encrypted messages. It is based on public key cryptography, where the private key is never shared and the public key can be distributed openly. The two main components and security features of S/MIME are:

Digital Signature

The sender signs the message with their private key, the recepiant verifies the sender's identity using the sender's public key. This security feature provides:

- Authentication: Confirms the sender's identity through their digital certificate
- Non-repudiation: Ensures the sender cannot deny sending the message
- Data Integrity: Detects any changes to the message after it's signed

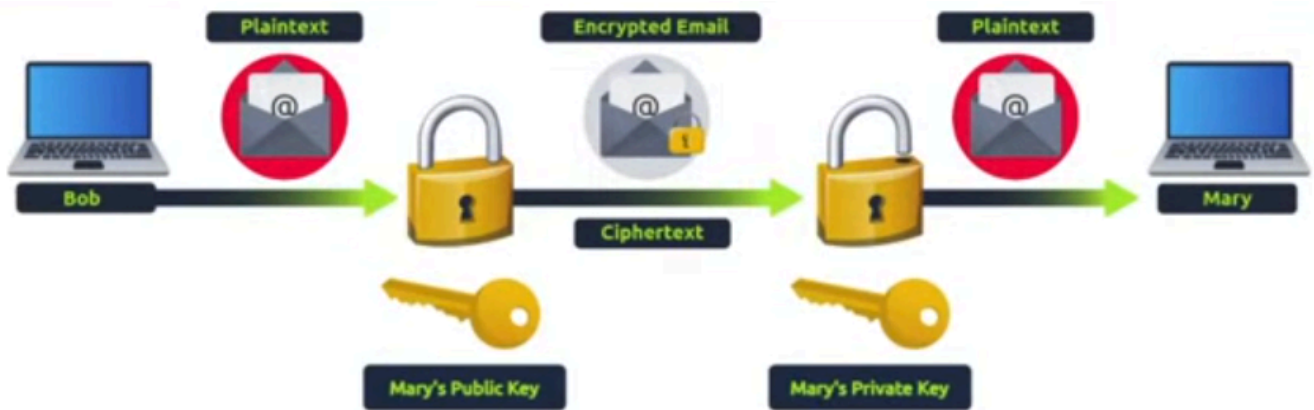
Encryption

The sender encrypts the message using the recipient's public key, allowing only the recipient to decrypt it with their private key. This security feature provides:

- Confidentiality: Keeps the content private and readable only by the intended recipient

S/MIME Example

- Bob wishes to securely send the email with S/MIME to Mary
- Bob creates a digital certificate to generate the Digital Signature
- Bob "signs" the email message with his private key (Digital Signature)
- Bob openly shares his public key with Mary (Digital Signature)
- Bob also asks the public key of Mary to encrypt the email (Encryption)
- Mary Verifies Bob's message with Bob's public key (Digital signature)
- Mary decrypts the received message with her private key (Encryption)
- To send a reply email, Mary performs the same procedure from the start
- Both Bob and Mary will now have each other's certificates for future correspondence



Analyzing SMTP Responses

Technical Defenses

Modern email systems employ various technical controls to help detect phishing messages before they reach users.

- **Email Filtering:** Provides filtering based on IP and domain reputation, allowing for blocking or quarantining of suspicious messages.
- **Secure Email Gateways (SEGs):** Scan messages to detect impersonation attempts, spoofing, and other phishing techniques that other filters might miss.
- **Link Rewriting:** Replaces suspicious or unknown URLs with safe, redirected ones, giving the system time to scan and verify the link.
- **Sandboxing:** Isolates and tests suspicious links or attachments in a secure, virtual environment to check for malicious behavior.

User-Facing Tools & Training

Even with strong technical defenses in place, some phishing emails will inevitably reach users. Giving users clear visual cues and education is essential.

- **Trust & Warning Indicators:** Modern email platforms display visual cues to help users understand if a message is safe. A banner may read "External Sender," "Suspicious Link," or signify that a message is from a trusted organization or sender.

- **Phishing Reporting:** Easy, in-email reporting options that let users quickly report suspicious messages.
- **User Awareness Training:** Train employees on identifying phishing attempts, social engineering tactics, and safe email practices.
- **Phishing Simulation Exercises:** Run controlled phishing campaigns to test and reinforce employee training.

